# Information Security Policy

| | |
|---|---|
| **Company** | Raízes Soluções e Tecnologia Ltda (CNPJ 51.467.037/0001-65) |
| **Version** | 1.0 |
| **Effective date** | 03 November 2026 |
| **Next review** | 03 November 2027 |
| **Owner** | Security and Privacy Officer, contato@raizesolucoes.com.br |
| **Approved by** | Management of Raízes Soluções e Tecnologia Ltda |

## 1. Purpose

This policy sets the information security program of Raízes Soluções e Tecnologia Ltda ("Raízes"). Its goal is to protect the confidentiality, integrity and availability of the information we process, including customer data and data we access from third-party platforms (marketplaces and ERPs) with the authorization of the account owner.

## 2. Scope

All employees, contractors and partners with access to Raízes systems or data.

All systems and services we operate or use: the Miller CRM and custom systems we build, source code, managed cloud services (Supabase on AWS, Vercel, GitHub, Google Workspace) and the computers used for work.

## 3. Governance

- Management approves this policy and provides the resources to apply it.
- The Security and Privacy Officer (contato@raizesolucoes.com.br) is responsible for the security program, incident handling and the annual review.
- Every production change is reviewed and merged by a second engineer before release.

## 4. Security principles

- Least privilege: people and systems receive only the access they need.
- Defense in depth: several independent controls protect the same asset.
- Customer isolation: each customer organization is logically isolated by row-level security enforced in the database.
- Encryption in transit (TLS) and at rest (provider-managed encryption).
- Secure development: code review, automated tests and security review before release.
- Secret management: credentials and tokens are stored server-side only and never in source code, browsers or logs.
- Data minimization: we collect and keep only what is needed for the service.
- Logging: security-relevant events are logged and audit logs are kept for 12 months.
- Third-party due diligence: providers must offer security controls adequate to the data they process.

## 5. Integrations with third-party platforms

- Access happens only through official APIs and only after the account owner authorizes our application (OAuth).

- Requested permissions are the minimum needed and are justified to the platform. Our code issues read requests only, unless the customer explicitly contracts an action.
- Access tokens and application secrets are kept on the server, in tables readable only by the server role, and are deleted when the owner disconnects the integration.
- We do not store personal data of our customers' buyers: a field allowlist keeps identifiers, dates, statuses, amounts and fees only, and automated tests verify it.

## 6. Supporting documents

- Infrastructure and Network Security Statement
- Endpoint Protection Standard
- Security Baseline for Accounts and Workstations
- Access Control Policy
- Data Classification and Encryption Policy
- Incident Response Plan
- Vulnerability and Threat Management Procedure
- Personal Data Protection Policy
- Business Impact Assessment (RTO and RPO)
- Business Continuity and Disaster Recovery Plan
- Incident Exercise Program and Report Template

## 7. Awareness and compliance

All staff are briefed on these documents when they join and at least once a year. Exceptions must be documented and approved by management. Violations may lead to removal of access and other measures allowed by law.

## 8. Review

This policy is reviewed at least once a year, and after any significant incident or change in our systems.

---